

DevOps Engineer**Technical Assessment — SaaS Infrastructure (Multi-Tenancy & Security)****Duration: 1-2 Days****Score: 100 pts****Format: Take-Home****Level: Mid-Senior**

Scenario

You are the first Platform Engineer at **TenantHub** — a fintech SaaS company. The product serves multiple enterprise clients (tenants) on a shared Kubernetes cluster. Each tenant processes sensitive financial data and must be strictly isolated. You have been given a running GKE cluster with no meaningful infra automation. Your task is to design and implement the three foundational pillars the platform is missing.

Tasks

Task 1 — Tenant Provisioning (35 pts)

A new tenant `acme-corp` needs to be onboarded. Automate the full provisioning flow:

- **Terraform module** — provision a dedicated PostgreSQL database and user for the tenant within an existing Cloud SQL instance. Must be idempotent.
- **Kubernetes manifests** — create a namespace `acme-corp`, a ServiceAccount, a Role granting read-only access to the tenant's own secrets only, and a RoleBinding.
- **GitHub Actions workflow** — triggered by adding a row to `tenants.yaml` in the repo. The workflow must run the Terraform module, create the K8s namespace + RBAC, and open a PR with the changes. It must be safe to re-run.
- **README** — explain what happens if the workflow is run twice for the same tenant (idempotency), and how you would extend this to 50 tenants without editing the workflow.

Task 2 — Secret Isolation & Security (35 pts)

Today all tenants share one Kubernetes Secret `app-env`. Any pod can read any tenant's credentials. Fix this:

- **Per-tenant secrets** — store each tenant's DB credentials in a separate GCP Secret Manager secret (e.g., `tenant-acme-corp-credentials`). Write the Terraform resource.
- **Workload Identity** — bind the tenant's Kubernetes ServiceAccount to a GCP service account that has `roles/secretmanager.secretAccessor` scoped only to that tenant's secret (not project-wide). Write both the Terraform IAM binding and the K8s annotation.
- **ExternalSecret** — write an `ExternalSecret` manifest that syncs the tenant secret into the namespace via External Secrets Operator.
- **Network Policy** — write a `NetworkPolicy` that allows a tenant pod to reach only the cluster DNS and its own database. Deny all other egress.
- **README** — in two paragraphs: (1) what attack is prevented by scoping the IAM binding to a single secret instead of the whole project, and (2) why a NetworkPolicy alone is not sufficient for tenant isolation in a shared-cluster SaaS model.

Task 3 — Infra Change Visibility (30 pts)

The team merges infra PRs without knowing what Kubernetes resources will actually change, and has no alerting when deployments break.

- **PR diff workflow** — GitHub Actions workflow that runs on every PR to the infra repo. It must run `kustomize build` on both the PR branch and `main`, diff the output, and post the result as a PR comment.
- **ArgoCD health alert** — write the ArgoCD `argocd-notifications-cm` ConfigMap entry that sends a Slack message whenever any Application transitions to `Degraded` or `OutOfSync`. The message must include the app name, environment, and a link to the ArgoCD UI.
- **README** — describe one real scenario where the PR diff workflow would have caught a mistake before it reached production.

Deliverables

Submit a GitHub repo (private is fine; add reviewer as collaborator) with the structure below. Include a `terraform plan` output as `task1/plan.txt` and a `kustomize build` output as `task3/kustomize-output.txt`. No live cloud account required — code quality is assessed, not deployed infra.

Scoring

Task	Focus	Points
Task 1	Tenant provisioning — Terraform, K8s RBAC, GitHub Actions workflow	35
Task 2	Secret isolation — Workload Identity, scoped IAM, ESO, NetworkPolicy	35
Task 3	Infra change visibility — PR diff, ArgoCD Slack alert	30
Total		100

We assess: correctness, idempotency, least-privilege security, and honest trade-off documentation in your READMEs. Incomplete solutions with clear reasoning score better than complete solutions with no explanation.